RISK REGISTER v1

Software Engineering Intelligence Platform

Security Architecture & Threat Modeling

Document Version	v1.0
Threat Model Source	Threat Dragon v2.2.0 — 113 threats
Risk Method	5×5 Likelihood × Impact
Assessment State	Initial / pre-treatment risk assessment
Owner	Security Track — Graduation Project

1. Purpose & Scope

This document is the risk-assessment layer for the existing Threat Dragon model. It covers all 113 Threat Dragon threats and adds the missing Likelihood, Impact, Risk Score and Risk Level fields. It intentionally does not recreate the already completed Critical Assets, Attack Surface, DFDs, STRIDE descriptions or mitigation text.

Traceability rule: every row retains the original Threat Dragon number (TD #). Similar or repeated risk themes across Level 0 and Level 1 remain traceable to their original threats, so coverage can be audited without creating duplicate threat-model work.

2. Risk Scoring Methodology

Risk Score = Likelihood × Impact. Both dimensions use a 1–5 scale.

Score	Risk Level	Meaning	Treatment expectation
1–4	Low	Lower exposure or limited consequence	Normal security work
5–9	Medium	Material risk requiring planned treatment	Assign owner and planned control
10–16	High	Significant security exposure	Prioritise remediation and validation
17–25	Critical	Severe security exposure	Immediate treatment / strong controls

Likelihood: 1 Rare · 2 Unlikely · 3 Possible · 4 Likely · 5 Almost Certain.

Impact: 1 Negligible · 2 Minor · 3 Moderate · 4 Major · 5 Severe.

Threat Dragon Severity is preserved as a separate source-model classification. It is not directly converted into the numeric risk score; the score is a preliminary architecture-based assessment of likelihood and impact.

3. Register Summary

Critical	High	Medium	Low
57	**43**	**13**	**0**

Total threats assessed: 113. All source threats remain Open pending implementation and security validation.

4. Risk Register — Complete 113 Threats

Sorted by Risk Score descending. TD # provides direct traceability to the Threat Dragon model.

Rank	TD #	Component / Flow	Threat	STRIDE	TD Severity	L	I	Score	Risk	Status
1	7	GitHub / Jira / Azure DevOps	Over-scoped OAuth token	Information disclosure	High	5	5	25	Critical	Open
2	23	Authentication service	Weak password storage	Information disclosure	High	5	5	25	Critical	Open
3	36	AI services	Internal AI API exposed without service auth	Elevation of privilege	Critical	5	5	25	Critical	Open
4	40	AI services	Sensitive ML predictions exposed to wrong audience	Information disclosure	High	5	5	25	Critical	Open
5	49	Multi-tenant SQL database	Missing tenant predicate on a query leaks everything	Information disclosure	Critical	5	5	25	Critical	Open
6	54	Vector database	No tenant namespace separation	Elevation of privilege	Critical	5	5	25	Critical	Open
7	60	Knowledge graph	Unauthenticated DB management interface	Elevation of privilege	High	5	5	25	Critical	Open
8	64	Secrets store	Single shared credential across all services	Elevation of privilege	High	5	5	25	Critical	Open
9	69	Authenticated API requests	Sensitive data exposed over transport	Information disclosure	High	5	5	25	Critical	Open
10	74	Repository and issue sync	Over-scoped token used for sync	Information disclosure	High	5	5	25	Critical	Open
11	76	AI request	Path that bypasses middleware	Elevation of privilege	Critical	5	5	25	Critical	Open
12	82	Read/write tenant data	Query executed without tenant scoping	Information disclosure	Critical	5	5	25	Critical	Open
13	86	Tenant-scoped retrieval	Retrieval without mandatory tenant filter	Elevation of privilege	Critical	5	5	25	Critical	Open
14	96	Retriever	Tenant or ACL filter omitted or overridable	Elevation of privilege	Critical	5	5	25	Critical	Open
15	104	Vector DB (per-tenant namespace)	Shared namespace across tenants	Elevation of privilege	Critical	5	5	25	Critical	Open
16	105	Vector DB (per-tenant namespace)	Raw vectors exposed through an API	Information disclosure	High	5	5	25	Critical	Open
17	109	Scoped similarity search	Filter omitted on the query	Elevation of privilege	Critical	5	5	25	Critical	Open
18	2	Flutter mobile client	Auth tokens/cached data insecurely stored	Information disclosure	High	4	5	20	Critical	Open
19	4	Flutter mobile client	Client-side authorization only / hidden UI still callable	Elevation of privilege	High	4	5	20	Critical	Open
20	9	External LLM provider API	Sensitive tenant data leaves trust boundary inside prompts	Information disclosure	Critical	4	5	20	Critical	Open
21	13	ASP.NET API gateway	Broken multi-tenant isolation / cross-tenant access	Elevation of privilege	Critical	4	5	20	Critical	Open
22	15	ASP.NET API gateway	IDOR on resource identifiers	Elevation of privilege	Critical	4	5	20	Critical	Open
23	20	Authentication service	Predictable/long-lived password reset tokens	Elevation of privilege	High	4	5	20	Critical	Open
24	27	Webhook receiver	SSRF via callback/repo URLs	Elevation of privilege	High	4	5	20	Critical	Open
25	28	SignalR real-time hub	Subscribe to another tenant's group	Elevation of privilege	High	4	5	20	Critical	Open
26	30	SignalR real-time hub	Over-broad broadcasts leak data between roles	Information disclosure	High	4	5	20	Critical	Open
27	35	Security middleware	Middleware can be skipped on some code paths	Elevation of privilege	Critical	4	5	20	Critical	Open
28	37	AI services	Retrieval returns chunks requester may not see	Information disclosure	Critical	4	5	20	Critical	Open
29	42	Background workers / ingestion	Workers run with excessive DB privileges	Elevation of privilege	High	4	5	20	Critical	Open
30	43	Background workers / ingestion	Secrets discovered in code persisted in plaintext	Information disclosure	Critical	4	5	20	Critical	Open
31	51	Multi-tenant SQL database	No encryption at rest/unprotected backups	Information disclosure	Medium	4	5	20	Critical	Open
32	52	Multi-tenant SQL database	High-privilege DB account	Elevation of privilege	High	4	5	20	Critical	Open
33	53	Multi-tenant SQL database	Personal/HR-sensitive fields stored unprotected	Information disclosure	High	4	5	20	Critical	Open
34	55	Vector database	Embedding inversion reconstructs source text	Information disclosure	High	4	5	20	Critical	Open
35	58	Knowledge graph	Graph exposes full internal org structure	Information disclosure	High	4	5	20	Critical	Open
36	62	Secrets store	Secrets committed to source control or baked into images	Information disclosure	Critical	4	5	20	Critical	Open
37	75	Real-time push	Events delivered to unauthorised subscribers	Information disclosure	High	4	5	20	Critical	Open
38	78	Prompt to external model	Confidential content sent outside trust boundary	Information disclosure	Critical	4	5	20	Critical	Open
39	83	Persist parsed	Secrets found in code persisted	Information	Critical	4	5	20	Critical	Open

Rank	TD #	Component / Flow	Threat	STRIDE	TD Severity	L	I	Score	Risk	Status
		entities	verbatim	disclosure						
40	88	Fetch credentials at runtime	Secrets cached in memory or logged on error	Information disclosure	High	4	5	20	Critical	Open
41	91	User chat input	Probing for other users' or tenants' information	Information disclosure	High	4	5	20	Critical	Open
42	93	Ingested content	Secrets and personal data ingested into the index	Information disclosure	Critical	4	5	20	Critical	Open
43	101	Output DLP and response validator	Sensitive content passed through to wrong user	Information disclosure	High	4	5	20	Critical	Open
44	106	Knowledge graph	Traversal crosses tenant or role boundaries	Information disclosure	High	4	5	20	Critical	Open
45	107	External LLM API	Prompt content retained or used for training	Information disclosure	Critical	4	5	20	Critical	Open
46	111	Prompt (post outbound DLP)	Unredacted sensitive content transmitted externally	Information disclosure	Critical	4	5	20	Critical	Open
47	113	Validated, redacted answer	Answer reveals content outside the user's permission set	Information disclosure	High	4	5	20	Critical	Open
48	14	ASP.NET API gateway	JWT validation weaknesses (alg confusion/unverified issuer)	Spoofing	High	5	4	20	Critical	Open
49	24	Webhook receiver	Missing HMAC signature verification	Spoofing	Critical	5	4	20	Critical	Open
50	32	Security middleware	DLP bypass via encoding/obfuscation/fragmentation	Tampering	High	5	4	20	Critical	Open
51	33	Security middleware	Prompt-injection filter bypass	Tampering	High	5	4	20	Critical	Open
52	45	Message queue	Unauthenticated message injection	Tampering	High	5	4	20	Critical	Open
53	72	Inbound webhook events	Unverified sender	Spoofing	Critical	5	4	20	Critical	Open
54	81	Consume jobs	Consumer accepts messages from unauthenticated producers	Spoofing	High	5	4	20	Critical	Open
55	94	Input sanitiser and injection filter	Bypass through paraphrase or non-English payloads	Tampering	High	5	4	20	Critical	Open
56	110	Delimited context + question	Context inserted without delimiters	Tampering	Critical	5	4	20	Critical	Open
57	112	Model response	Response trusted without validation	Tampering	High	5	4	20	Critical	Open
58	1	Flutter mobile client	Stolen/replayed JWT impersonation	Spoofing	High	4	4	16	High	Open
59	5	GitHub / Jira / Azure DevOps	Forged webhook unsigned payloads	Spoofing	Critical	4	4	16	High	Open
60	6	GitHub / Jira / Azure DevOps	Poisoned repository content drives indirect prompt injection	Tampering	Critical	4	4	16	High	Open
61	12	External LLM provider API	Model output treated as trusted/rendered/executed	Tampering	High	4	4	16	High	Open
62	19	Authentication service	Credential stuffing/brute force	Spoofing	High	4	4	16	High	Open
63	22	Authentication service	Refresh tokens not rotated/revocable	Tampering	High	4	4	16	High	Open
64	25	Webhook receiver	Replay of captured valid webhook	Tampering	High	4	4	16	High	Open
65	29	SignalR real-time hub	Unauthenticated hub connections	Spoofing	Medium	4	4	16	High	Open
66	38	AI services	System-prompt override through direct prompt injection	Tampering	Critical	4	4	16	High	Open
67	41	Background workers / ingestion	Untrusted repository content processed unsafely	Tampering	High	4	4	16	High	Open
68	50	Multi-tenant SQL database	SQL injection via dynamic query construction	Tampering	High	4	4	16	High	Open
69	56	Vector database	Index poisoning manipulates retrieved answers	Tampering	High	4	4	16	High	Open
70	59	Knowledge graph	Query injection via user-supplied graph params	Tampering	High	4	4	16	High	Open
71	65	Audit log	Log records can be modified or deleted	Tampering	High	4	4	16	High	Open
72	71	Login and token refresh	Credentials intercepted or replayed	Spoofing	High	4	4	16	High	Open
73	73	Inbound webhook events	Payload replay or tampering	Tampering	High	4	4	16	High	Open
74	77	Filtered prompt + tenant context	Tenant context spoofed on internal call	Tampering	Critical	4	4	16	High	Open
75	80	Enqueue ingestion and analysis commands	Unvalidated payload enqueued for privileged processing	Tampering	High	4	4	16	High	Open
76	84	Write embeddings	Poisoned chunks inserted into index	Tampering	High	4	4	16	High	Open
77	87	Graph queries	Cypher injection via search parameters	Tampering	High	4	4	16	High	Open
78	90	User chat	Direct prompt injection	Tampering	Critical	4	4	16	High	Open

Rank	TD #	Component / Flow	Threat	STRIDE	TD Severity	L	I	Score	Risk	Status
		input								
79	92	Ingested content	Indirect prompt injection through poisoned content	Tampering	Critical	4	4	16	High	Open
80	98	LLM orchestrator	Retrieved content merged into instruction channel	Tampering	Critical	4	4	16	High	Open
81	102	Output DLP and response validator	Rendered output carries active content	Tampering	High	4	4	16	High	Open
82	108	Sanitised query + verified identity	Identity claim not cryptographically bound	Spoofing	Critical	4	4	16	High	Open
83	21	Authentication service	User enumeration through differential responses	Information disclosure	Medium	3	5	15	High	Open
84	46	Message queue	Message payloads readable in transit/at rest	Information disclosure	Medium	3	5	15	High	Open
85	67	Audit log	Sensitive data written into logs	Information disclosure	Medium	3	5	15	High	Open
86	97	Retriever	Chunk metadata leaks document titles user cannot open	Information disclosure	Medium	3	5	15	High	Open
87	66	Audit log	No integrity protection or time source guarantee	Repudiation	High	5	3	15	High	Open
88	3	Flutter mobile client	TLS interception via rogue/user CA	Tampering	Medium	3	4	12	High	Open
89	16	ASP.NET API gateway	Mass assignment / over-posting	Tampering	Medium	3	4	12	High	Open
90	85	Update graph relationships	Fabricated relationships distort analytics	Tampering	Medium	3	4	12	High	Open
91	8	GitHub / Jira / Azure DevOps	No provenance recorded for ingested artifacts	Repudiation	Medium	4	3	12	High	Open
92	10	External LLM provider API	Cost exhaustion through unbounded model calls	DoS	Medium	4	3	12	High	Open
93	17	ASP.NET API gateway	Expensive unauthenticated/low-cost endpoints	DoS	Medium	4	3	12	High	Open
94	39	AI services	Unbounded context assembly/model inference cost	DoS	Medium	4	3	12	High	Open
95	48	Message queue	No ordering/idempotency guarantees	Repudiation	Medium	4	3	12	High	Open
96	61	Knowledge graph	Unbounded traversals exhaust memory	DoS	Medium	4	3	12	High	Open
97	63	Secrets store	No rotation policy and no access logging	Repudiation	Medium	4	3	12	High	Open
98	89	Emit audit events	Audit write failures silently ignored	Repudiation	High	4	3	12	High	Open
99	99	LLM orchestrator	Unbounded context assembly	DoS	Medium	4	3	12	High	Open
100	100	LLM orchestrator	No traceability from answer to sources	Repudiation	Medium	4	3	12	High	Open
101	11	External LLM provider API	Prompts/completions not logged for accountability	Repudiation	Medium	3	3	9	Medium	Open
102	18	ASP.NET API gateway	Security-relevant actions not attributable	Repudiation	Medium	3	3	9	Medium	Open
103	26	Webhook receiver	Webhook flooding/oversized payloads	DoS	Medium	3	3	9	Medium	Open
104	31	SignalR real-time hub	Connection exhaustion	DoS	Medium	3	3	9	Medium	Open
105	34	Security middleware	Filtering decisions not logged	Repudiation	Medium	3	3	9	Medium	Open
106	47	Message queue	Queue flooding starves legitimate work	DoS	Medium	3	3	9	Medium	Open
107	57	Vector database	Expensive similarity queries degrade service	DoS	Medium	3	3	9	Medium	Open
108	68	Audit log	Log volume exhausts storage and stops application	DoS	Medium	3	3	9	Medium	Open
109	70	Authenticated API requests	Request flooding from single client	DoS	Medium	3	3	9	Medium	Open
110	79	Prompt to external model	Provider outage or throttling breaks core features	DoS	Medium	3	3	9	Medium	Open
111	103	Output DLP and response validator	Redaction actions not recorded	Repudiation	Medium	3	3	9	Medium	Open
112	44	Background workers / ingestion	Silent job failures leave incomplete/stale analysis	Repudiation	Low	2	3	6	Medium	Open
113	95	Input sanitiser and injection filter	Filter latency added to every AI request	DoS	Low	2	3	6	Medium	Open

5. Threat Dragon Score Mapping

The exported Threat Dragon JSON contains an empty score field for every threat. The table below gives the exact numeric score to enter for each TD # using this register's 5×5 methodology.

TD #	Likelihood	Impact	Score	Risk Level
1	4	4	16	High
2	4	5	20	Critical
3	3	4	12	High
4	4	5	20	Critical
5	4	4	16	High
6	4	4	16	High
7	5	5	25	Critical
8	4	3	12	High
9	4	5	20	Critical
10	4	3	12	High
11	3	3	9	Medium
12	4	4	16	High
13	4	5	20	Critical
14	5	4	20	Critical
15	4	5	20	Critical
16	3	4	12	High
17	4	3	12	High
18	3	3	9	Medium
19	4	4	16	High
20	4	5	20	Critical
21	3	5	15	High
22	4	4	16	High
23	5	5	25	Critical
24	5	4	20	Critical
25	4	4	16	High
26	3	3	9	Medium
27	4	5	20	Critical
28	4	5	20	Critical
29	4	4	16	High
30	4	5	20	Critical
31	3	3	9	Medium
32	5	4	20	Critical
33	5	4	20	Critical
34	3	3	9	Medium
35	4	5	20	Critical
36	5	5	25	Critical
37	4	5	20	Critical
38	4	4	16	High
39	4	3	12	High
40	5	5	25	Critical
41	4	4	16	High
42	4	5	20	Critical
43	4	5	20	Critical
44	2	3	6	Medium
45	5	4	20	Critical
46	3	5	15	High
47	3	3	9	Medium
48	4	3	12	High
49	5	5	25	Critical
50	4	4	16	High
51	4	5	20	Critical
52	4	5	20	Critical
53	4	5	20	Critical
54	5	5	25	Critical
55	4	5	20	Critical
56	4	4	16	High
57	3	3	9	Medium
58	4	5	20	Critical
59	4	4	16	High
60	5	5	25	Critical
61	4	3	12	High
62	4	5	20	Critical
63	4	3	12	High
64	5	5	25	Critical
65	4	4	16	High
66	5	3	15	High
67	3	5	15	High
68	3	3	9	Medium
69	5	5	25	Critical

TD #	Likelihood	Impact	Score	Risk Level
70	3	3	9	Medium
71	4	4	16	High
72	5	4	20	Critical
73	4	4	16	High
74	5	5	25	Critical
75	4	5	20	Critical
76	5	5	25	Critical
77	4	4	16	High
78	4	5	20	Critical
79	3	3	9	Medium
80	4	4	16	High
81	5	4	20	Critical
82	5	5	25	Critical
83	4	5	20	Critical
84	4	4	16	High
85	3	4	12	High
86	5	5	25	Critical
87	4	4	16	High
88	4	5	20	Critical
89	4	3	12	High
90	4	4	16	High
91	4	5	20	Critical
92	4	4	16	High
93	4	5	20	Critical
94	5	4	20	Critical
95	2	3	6	Medium
96	5	5	25	Critical
97	3	5	15	High
98	4	4	16	High
99	4	3	12	High
100	4	3	12	High
101	4	5	20	Critical
102	4	4	16	High
103	3	3	9	Medium
104	5	5	25	Critical
105	5	5	25	Critical
106	4	5	20	Critical
107	4	5	20	Critical
108	4	4	16	High
109	5	5	25	Critical
110	5	4	20	Critical
111	4	5	20	Critical
112	5	4	20	Critical
113	4	5	20	Critical

6. Integration with the Existing Security Work

- Threat Dragon remains the source of truth for threat scenarios, DFDs, STRIDE classification and proposed mitigations.
- Risk Register v1 is the missing risk-assessment layer: Likelihood + Impact + Score + Risk Level + Rank.
- Do not copy the existing Threat Dragon mitigation text into this register unless a later version needs treatment ownership or residual-risk tracking.
- After controls are implemented, validate them through the Security Testing Framework before changing treatment status.
- Recalculate residual risk after validation rather than assuming that a proposed mitigation has reduced risk.

7. Document Control

Version	Date	Change
1.0	23 Sep 2026	Initial Risk Register v1 — all 113 Threat Dragon threats